



Board Executive Deck — Cybersecurity Gap Analysis & ISO 27001 Readiness

Relazione Strategica per il Consiglio di Amministrazione — Aetheris Therapeutics S.p.A.

Destinatari: Chief Executive Officer (CEO), Consiglio di Amministrazione (Board of Directors)

Relatore: Emanuele Tarchi (ISO/IEC 27001 Lead Auditor Trainee)

Rif. Documento: EXEC-BRD-2026-05

Data di Presentazione: 20 Agosto 2026

Classificazione: Riservato / Strettamente Riservato al Board

1. Executive Summary & Posizione della Sicurezza

L'audit indipendente condotto ad **Agosto 2026** sulla postura di sicurezza e sul livello di compliance di **Aetheris Therapeutics S.p.A.** evidenzia una situazione di **alto rischio operativo e legale**, a fronte di un'infrastruttura tecnologica di base adeguata.

Sintesi dei Risultati

- Livello di Maturità Attuale:** 1.74 / 5.0 (Tier 1 - Reattivo / Informale) secondo la scala NIST CSF.
- Tasso di Conformità ISO 27001 Annex A:** 4.3% (Conformi solo 4 controlli su 93).
- Esito Audit di Certificazione:** **NON SUPERATO (FAIL)** — Presenti **5 Non-Conformità Maggiori** bloccanti.

2. I 3 Rischi Principali per il Business (Top Enterprise Risks)

Se non affrontate immediatamente con il piano di remediation proposto, le vulnerabilità riscontrate espongono l'organizzazione a tre scenari d'impatto critico:

Rischio Enterprise	Causa Radice Riscontrata nell'Audit	Impatto Finanziario / Legale Stimato
Esfiltrazione Brevetti R&D	Accessi VPN privi di MFA e assenza di controllo sulle utenze amministrative (PAM).	> € 2.000.000 (Perdita del vantaggio competitivo ed esproprio IP).
Sanzioni GDPR & Blocco Clinico	Mancanza del Registro dei Trattamenti (Art. 30) per i dati sanitari e assenza di IRP.	Fino a € 10.000.000 (4% del fatturato ex Art. 83 GDPR + blocco Garante).
Infezione Ransomware Estesa	Assenza di un SIEM centralizzato e di un presidio SOC h24 per il blocco delle minacce.	€ 500.000 – € 1.500.000 (Danno da fermo macchina e ripristino).

3. Matrice Sintetica di Conformità (As-Is vs To-Be)

Ripartizione Rilievi d'Audit

- Non-Conformità Maggiori (NC Major):** 5 (31.2%)
- Non-Conformità Minori (NC Minor):** 4 (25.0%)
- Opportunità di Miglioramento (OFI):** 3 (18.8%)
- Controlli Conformi (PASS):** 4 (25.0%)

Target di Maturità per Dominio NIST (Target 12 Mesi)

- NIST ID (Identify):** 1.4 → 3.5 →

- NIST PR (Protect): 2.1 → 4.0 [██████████] → [██████████]
- NIST DE (Detect): 1.2 → 3.5 [██████████] → [██████████]
- NIST RS (Respond): 1.0 → 3.5 [██████████] → [██████████]
- NIST RC (Recover): 3.0 → 4.0 [██████████] → [██████████]

4. Piano Economico e Trattamento del Rischio (Business Case)

Per azzerare i rischi critici e preparare Aetheris Therapeutics S.p.A. all'ottenimento della Certificazione ISO/IEC 27001:2022 entro **12 mesi**, si richiede l'approvazione del **Risk Treatment Plan (RTP)** e l'allocazione del seguente budget straordinario:

Macro-Area d'Investimento	Soluzione Tecnologica / Consulenziale	Investimento Anno 1
Identity & Access Security	Rollout MFA Microsoft Entra ID + Licenze PAM Vault (CyberArk / Delinea).	€ 15.000
Security Operations 24/7	Deploy SIEM Microsoft Sentinel + Canone Servizio MSSP/SOC h24.	€ 42.000
GRC & GDPR Advisory	Incarico consulenza esterna per Registro Art. 30 GDPR, Policy SGSI e Internal Audit.	€ 13.000
TOTALE BUDGET RICHiesto	Allocazione per il primo anno di attuazione del Risk Treatment Plan (RTP)	€ 70.000

5. ROI della Sicurezza e Benefici per il Business

L'approvazione del budget di **€ 70.000** genera un ritorno diretto per l'organizzazione in termini di:

1. **Abbattimento dell'Esposizione Finanziaria:** Riduzione di oltre il **90%** del rischio di sanzioni GDPR (fino a € 10M) e perdite operative da ransomware.
2. **Vantaggio Competitivo nei Bandi R&D:** La certificazione ISO 27001 costituisce un requisito premiale e abilitante per la stipula di partnership con multinazionali farmaceutiche ed enti sanitari pubblici.
3. **Resilienza Operativa Garantita:** Monitoraggio proattivo degli incidenti con capacità di contenimento ed escalation entro 15 minuti.

6. Delibera Formale del Consiglio di Amministrazione

Il Consiglio di Amministrazione di **Aetheris Therapeutics S.p.A.**, vista la presente relazione strategica e il Risk Treatment Plan associato:

- *  **APPROVA** l'avvio del programma di remediation per il raggiungimento della certificazione ISO/IEC 27001:2022.
- *  **AUTORIZZA** lo stanziamento del budget di **€ 70.000** da distribuire sul piano di lavoro a 12 mesi.
- *  **NOMINA** l'IT Director e il Team GRC quali responsabili dell'esecuzione e del reporting trimestrale al Board.

7. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	20 Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	21 Agosto 2026
Approvato da (Board / CEO)	Chief Executive Officer (CEO)	Approvato	22 Agosto 2026